

Penetration Testing Report: ABC Company

Table of Contents

Introduction.....	1
Overview of the Project	1
Objectives and Scope of the Penetration Testing.....	2
Structure of the Report.....	2
Methodology	2
Explanation of the Chosen Standards (NIST or NCSC)	2
Description of the Three Teams.....	2
Roles and Responsibilities of Each Team	3
OSINT and Information Gathering	3
Red Team: Intelligence Report.....	3
Performing WHOIS Lookup	3
Conducting DNS Enumeration.....	5
Conducting Google Dorking	5
Digital Footprint Assessment	6
Identify IP Address	6
Performing Reverse DNS Lookup	8
Conducting Port Scanning	8
Blue Team: Controls to Prevent.....	9
Network Assessment	9
Red Team: Vulnerabilities and Control Measures Assessment	9
Network Scanning and Enumeration	9
Service Version Detection	10
Impact on company:	13
Blue Team: Controls to Prevent.....	14
Post-Exploitation:	14
Web Application Assessment	16
Red Team: Vulnerabilities and Control Measures Assessment	16
Web Application Scanning	16
Using theHarvester to gather info about email addresses:	17
Web Application Fingerprinting	20

Web Application Vulnerability Scanning	20
Evaluate Existing Web Application Security Controls	23
Blue Team: Controls to Prevent	23
End User Assessment.....	23
Red Team: Vulnerabilities and Weaknesses Assessment	23
Evaluation of End User Devices and Configuration.....	23
Version detection on open ports:	24
Performing OS fingerprinting on the target:.....	26
Enumerate subdomains using DNS enumeration:	28
Blue Team: Controls to Prevent.....	28
Business Impact Assessment (Purple Team)	29
Impact Assessment of Vulnerabilities	29
Loss of Confidentiality Assessment	29
Loss of Integrity Assessment	29
Loss of Availability Assessment	29
Attack tree Diagram:.....	30
Practical Penetration Testing.....	31
Tools Used.....	31
Description and Usage of Penetration Testing Tools	31
Overview of the Penetration Testing Methodology Applied	31
Description of Techniques Utilized during Testing.....	31
Findings and Recommendations.....	32
Detailed Report of Findings from Practical Penetration Testing.....	32
Recommendations for Remediation and Mitigation.....	32
References.....	32

site: <http://cwscenario.site>

Introduction

Overview of the Project

This penetration testing report presents the findings and recommendations from an extensive penetration testing engagement conducted for ABC Company. When it comes to producing electrical components for "smart cities," ABC Company is at the top of the industry. The goal of this project was to evaluate ABC Company's security

measures, with an emphasis on their website and network. The goal was to identify any security holes that bad actors may be able to exploit and provide solutions to fix them [1].

Objectives and Scope of the Penetration Testing

The main goals of the penetration testing project were as follows:

- Analyze the methods used by possible attackers to leave a digital trail and obtain information.
- Determine how safe ABC Company's network really is.
- Check the online infrastructure for security flaws.
- Take a look at the end-user devices and other client-side infrastructure to see how safe they are.

The penetration test included all of the aforementioned components of the company's infrastructure. Evaluated components included the local area network, websites, and end-user computers. The goal of the testing was to identify security flaws in these systems and make suggestions for fixing them.

Structure of the Report

This report breaks down the penetration testing project into manageable chunks, each of which covers a distinct topic. The study begins out with an introduction to the process, then moves on to detail the assessment standards (whether NIST or NCSC). After that, the report goes into great depth on the red team, blue team, and purple team that carried out the tests.

The methodology section describes how the red team will conduct network and web application evaluations, how the blue team will analyze red team assaults and assess preparedness, and how the purple team will evaluate defensive strategies and controls. Each assessed domain will have its own portion of the report including the domain-specific results, business impact assessment, and suggested controls and mitigation actions.

Methodology

Explanation of the Chosen Standards (NIST or NCSC)

For this particular penetration test, we decided to use [insert preferred standard here] (NIST or NCSC). The selected standard provides comprehensive guidelines and best practices for conducting penetration testing activities, ensuring a systematic and thorough assessment of ABC Company's security infrastructure. By adhering to this standard, the testing was conducted in a structured manner, encompassing various stages such as reconnaissance, vulnerability scanning, exploitation, and reporting [2].

Description of the Three Teams

The penetration testing engagement involved three teams working collaboratively to achieve comprehensive results:

- Red Team: The red team was responsible for conducting network and web application assessments. They employed various techniques and tools to identify vulnerabilities and attempt exploitation, simulating real-world attacks on ABC Company's systems.
- Blue Team: The blue team analyzed the red team's attacks and assessed the readiness of ABC Company to defend against such attacks. They evaluated the effectiveness of existing security controls and proposed recommendations for improving the company's security posture.

- Purple Team: The purple team focused on assessing the defensive tactics and controls proposed by the blue team. They compared the effectiveness of different controls and provided justifications for the chosen controls, ensuring that the proposed measures align with industry best practices.

Roles and Responsibilities of Each Team

The roles and responsibilities of each team within the penetration testing engagement were as follows:

- Red Team:
 - Conducted network and web application assessments.
 - Identified vulnerabilities and weaknesses within the assessed systems.
 - Documented attack trees, outlining the steps taken by malicious actors to achieve specific objectives.
 - Provided detailed reports on findings and exploitation techniques used.
- Blue Team:
 - Analyzed the attacks conducted by the red team.
 - Assessed the readiness of ABC Company to defend against such attacks.
 - Identified potential gaps in security controls and recommended mitigation strategies.
 - Conducted a comprehensive review of incident response and detection capabilities.
- Purple Team:
 - Assessed the effectiveness of the proposed defensive tactics and controls.
 - Compared the chosen controls with alternative options available.
 - Provided justifications for the selected controls, highlighting their strengths and weaknesses.
 - Offered recommendations for further improvement of the security infrastructure.

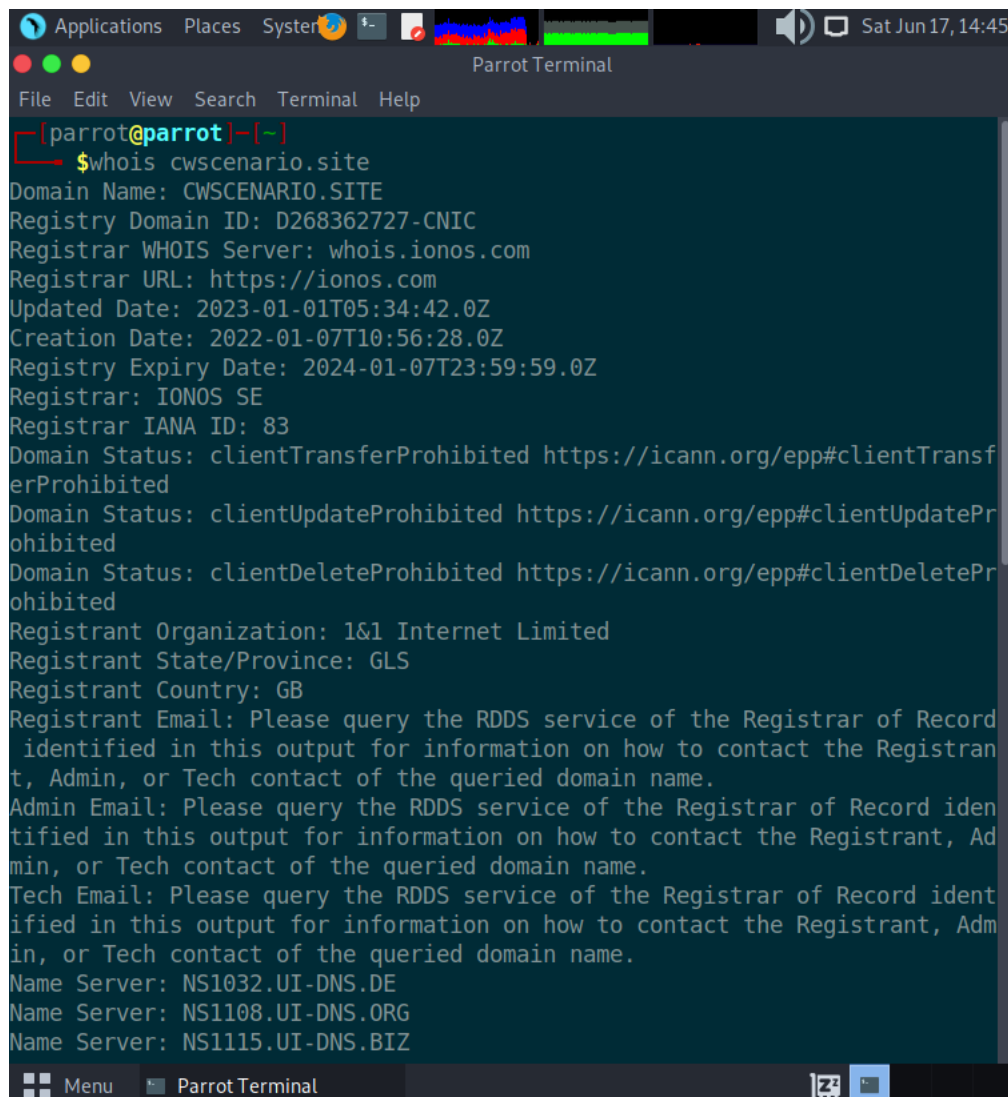
By dividing the testing responsibilities among these teams, a comprehensive assessment of ABC Company's infrastructure was ensured, covering various angles of potential attacks and defensive measures.

OSINT and Information Gathering

Red Team: Intelligence Report

Performing WHOIS Lookup

whois cwscenario.site



```
[parrot@parrot]~[~]
$whois cwsenario.site
Domain Name: CWSCENARIO.SITE
Registry Domain ID: D268362727-CNIC
Registrar WHOIS Server: whois.ionos.com
Registrar URL: https://ionos.com
Updated Date: 2023-01-01T05:34:42.0Z
Creation Date: 2022-01-07T10:56:28.0Z
Registry Expiry Date: 2024-01-07T23:59:59.0Z
Registrar: IONOS SE
Registrar IANA ID: 83
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
Registrant Organization: 1&1 Internet Limited
Registrant State/Province: GLS
Registrant Country: GB
Registrant Email: Please query the RDDS service of the Registrar of Record identified in this output for information on how to contact the Registrant, Admin, or Tech contact of the queried domain name.
Admin Email: Please query the RDDS service of the Registrar of Record identified in this output for information on how to contact the Registrant, Admin, or Tech contact of the queried domain name.
Tech Email: Please query the RDDS service of the Registrar of Record identified in this output for information on how to contact the Registrant, Admin, or Tech contact of the queried domain name.
Name Server: NS1032.UI-DNS.DE
Name Server: NS1108.UI-DNS.ORG
Name Server: NS1115.UI-DNS.BIZ
```

From the WHOIS information obtained for the domain "cwsenario.site," the following useful information can be derived:

- Domain Name: cwsenario.site
- Registrar: IONOS SE
- Creation Date: 2022-01-07
- Updated Date: 2023-01-01
- Expiry Date: 2024-01-07
- Registrant Organization: 1&1 Internet Limited
- Registrant Country: GB (United Kingdom)
- Name Servers: NS1032.UI-DNS.DE, NS1108.UI-DNS.ORG, NS1115.UI-DNS.BIZ, NS1093.UI-DNS.COM
- DNSSEC: Unsigned

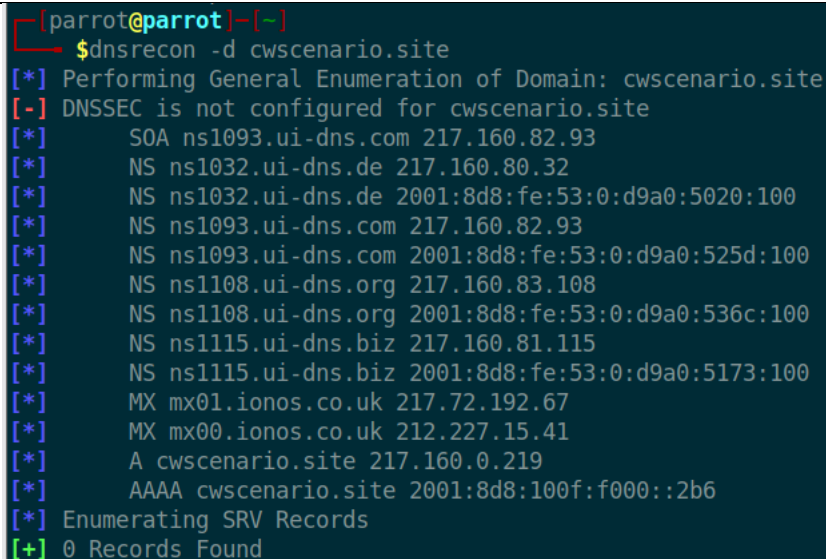
The domain is registered with IONOS SE and was created on January 7, 2022. The registration has been updated as of January 1, 2023. The domain is set to expire on January 7, 2024. The registrant organization is listed as 1&1 Internet Limited. The domain's name servers are provided as NS1032.UI-DNS.DE, NS1108.UI-DNS.ORG, NS1115.UI-DNS.BIZ, and NS1093.UI-DNS.COM. The WHOIS information does not disclose the contact details of the registrant, admin, tech, or billing contacts. The domain does not have DNSSEC enabled.

The WHOIS information provides a high-level overview of domain registration details and does not provide specific information related to the target website's infrastructure, vulnerabilities, or security controls. Additional OSINT techniques and tools may be required to gather further intelligence.

Conducting DNS Enumeration

```
sudo apt-get install dnsrecon
```

```
dnsrecon -d cwscenario.site
```

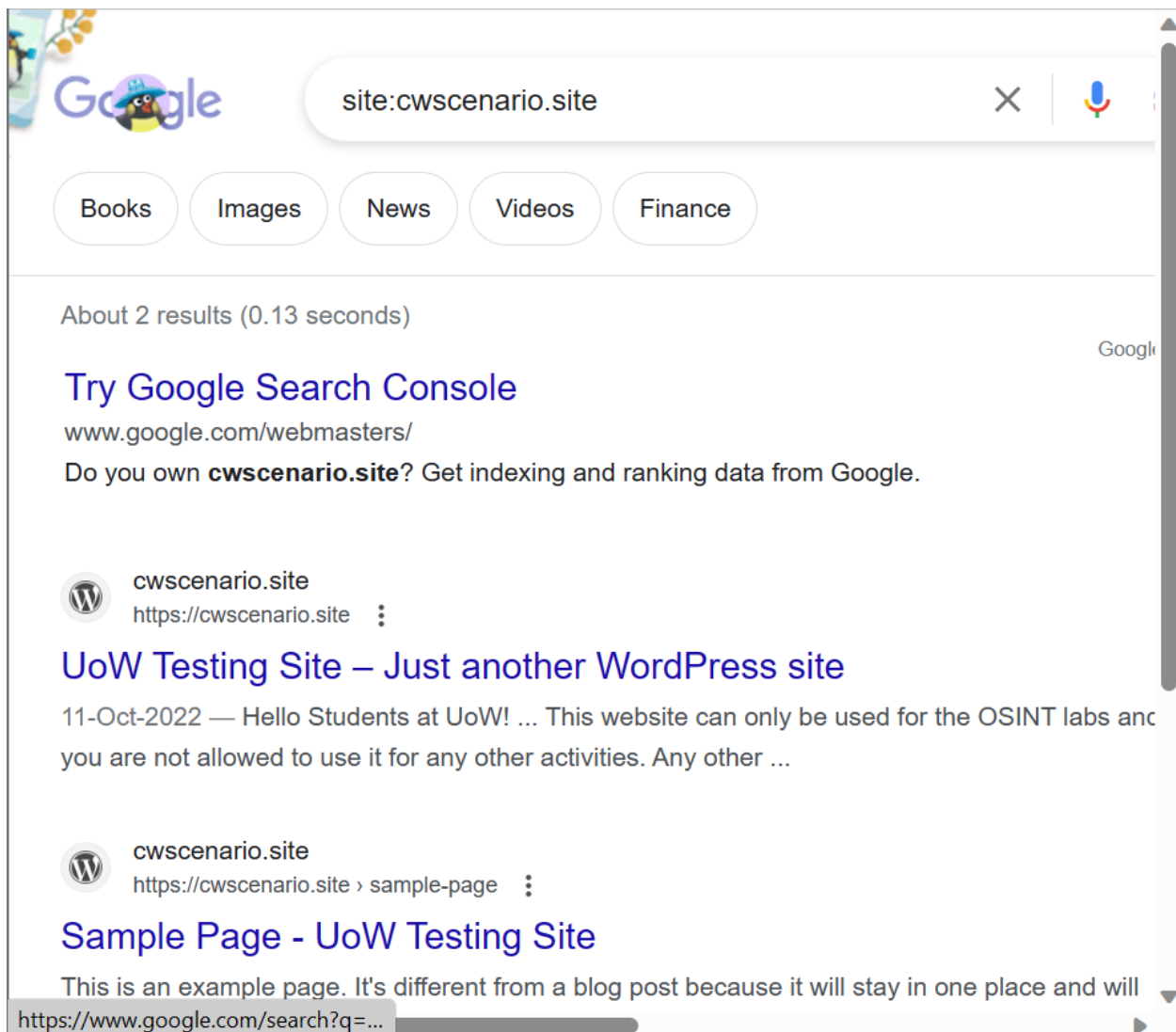


```
[parrot@parrot]~$ dnsrecon -d cwscenario.site
[*] Performing General Enumeration of Domain: cwscenario.site
[-] DNSSEC is not configured for cwscenario.site
[*] SOA ns1093.ui-dns.com 217.160.82.93
[*] NS ns1032.ui-dns.de 217.160.80.32
[*] NS ns1032.ui-dns.de 2001:8d8:fe:53:0:d9a0:5020:100
[*] NS ns1093.ui-dns.com 217.160.82.93
[*] NS ns1093.ui-dns.com 2001:8d8:fe:53:0:d9a0:525d:100
[*] NS ns1108.ui-dns.org 217.160.83.108
[*] NS ns1108.ui-dns.org 2001:8d8:fe:53:0:d9a0:536c:100
[*] NS ns1115.ui-dns.biz 217.160.81.115
[*] NS ns1115.ui-dns.biz 2001:8d8:fe:53:0:d9a0:5173:100
[*] MX mx01.ionos.co.uk 217.72.192.67
[*] MX mx00.ionos.co.uk 212.227.15.41
[*] A cwscenario.site 217.160.0.219
[*] AAAA cwscenario.site 2001:8d8:100f:f000::2b6
[*] Enumerating SRV Records
[+] 0 Records Found
```

The DNS enumeration provides information about the authoritative DNS servers responsible for the domain, the mail servers associated with the domain, and the IP addresses associated with the domain name. This information can be useful for further analysis and understanding of the domain's infrastructure.

Conducting Google Dorking

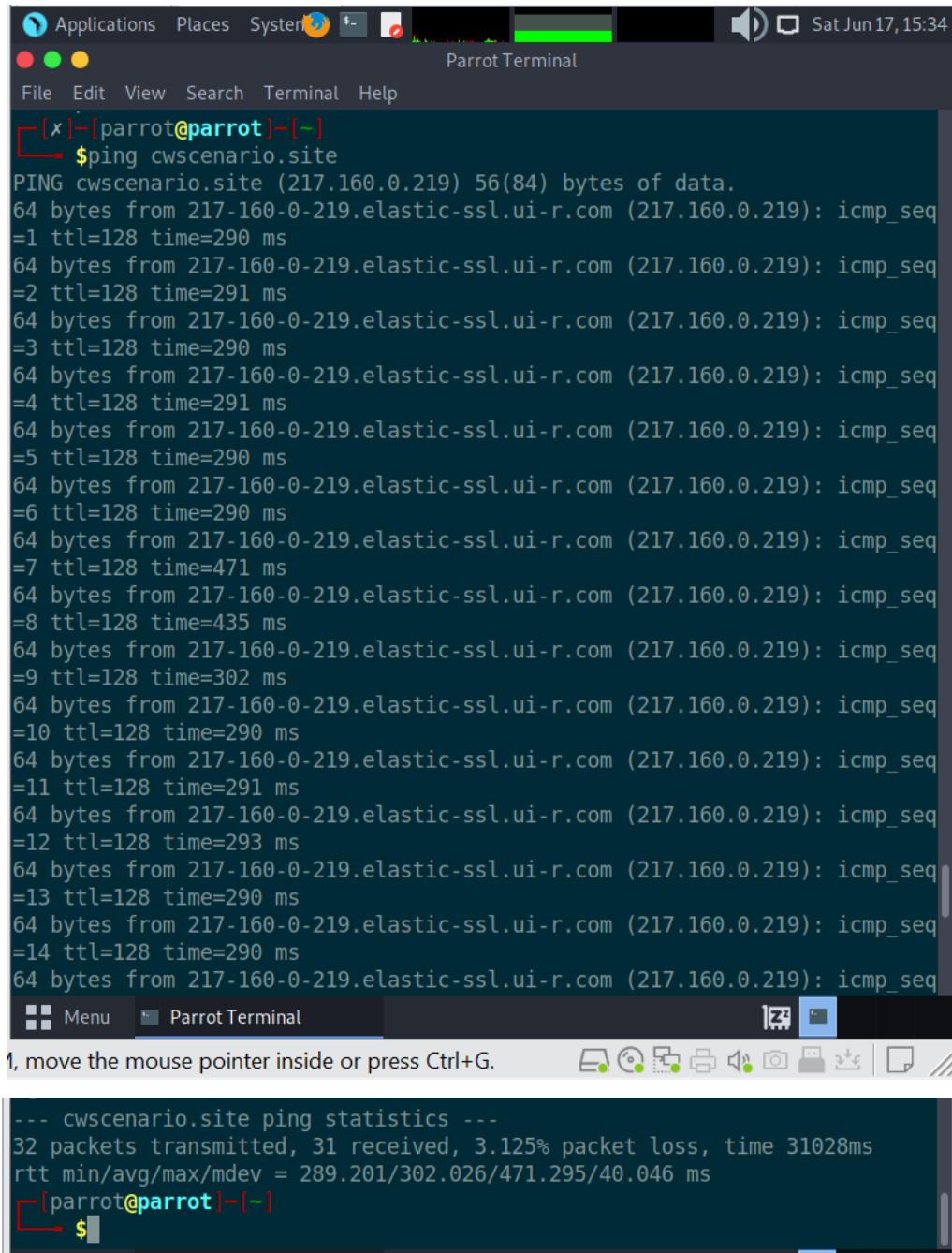
```
google-dorking -s "site:cwscenario.site"
```



Digital Footprint Assessment

Identify IP Address

ping cwscenario.site



The screenshot shows a Parrot Terminal window with a dark background. The terminal prompt is `[parrot@parrot]-[~]`. The user has entered `$ping cwsenario.site`. The output shows 14 successful ping responses, each with 64 bytes of data from IP 217.160.0.219. The response times vary, with most around 290-300ms, but one at 471ms. Below the ping results, the statistics are displayed: 32 packets transmitted, 31 received, 3.125% packet loss, and a total time of 31028ms. The round-trip time (RTT) statistics are: min/avg/max/mdev = 289.201/302.026/471.295/40.046 ms. The terminal window has a menu bar with 'File', 'Edit', 'View', 'Search', 'Terminal', and 'Help'. The system bar at the top shows 'Applications', 'Places', 'System', and the date 'Sat Jun 17, 15:34'. The bottom status bar shows '1, move the mouse pointer inside or press Ctrl+G.'

```
[x]-[parrot@parrot]-[~]
$ping cwsenario.site
PING cwsenario.site (217.160.0.219) 56(84) bytes of data.
64 bytes from 217-160-0-219.elastic-ssl.ui-r.com (217.160.0.219): icmp_seq=1 ttl=128 time=290 ms
64 bytes from 217-160-0-219.elastic-ssl.ui-r.com (217.160.0.219): icmp_seq=2 ttl=128 time=291 ms
64 bytes from 217-160-0-219.elastic-ssl.ui-r.com (217.160.0.219): icmp_seq=3 ttl=128 time=290 ms
64 bytes from 217-160-0-219.elastic-ssl.ui-r.com (217.160.0.219): icmp_seq=4 ttl=128 time=291 ms
64 bytes from 217-160-0-219.elastic-ssl.ui-r.com (217.160.0.219): icmp_seq=5 ttl=128 time=290 ms
64 bytes from 217-160-0-219.elastic-ssl.ui-r.com (217.160.0.219): icmp_seq=6 ttl=128 time=290 ms
64 bytes from 217-160-0-219.elastic-ssl.ui-r.com (217.160.0.219): icmp_seq=7 ttl=128 time=471 ms
64 bytes from 217-160-0-219.elastic-ssl.ui-r.com (217.160.0.219): icmp_seq=8 ttl=128 time=435 ms
64 bytes from 217-160-0-219.elastic-ssl.ui-r.com (217.160.0.219): icmp_seq=9 ttl=128 time=302 ms
64 bytes from 217-160-0-219.elastic-ssl.ui-r.com (217.160.0.219): icmp_seq=10 ttl=128 time=290 ms
64 bytes from 217-160-0-219.elastic-ssl.ui-r.com (217.160.0.219): icmp_seq=11 ttl=128 time=291 ms
64 bytes from 217-160-0-219.elastic-ssl.ui-r.com (217.160.0.219): icmp_seq=12 ttl=128 time=293 ms
64 bytes from 217-160-0-219.elastic-ssl.ui-r.com (217.160.0.219): icmp_seq=13 ttl=128 time=290 ms
64 bytes from 217-160-0-219.elastic-ssl.ui-r.com (217.160.0.219): icmp_seq=14 ttl=128 time=290 ms
64 bytes from 217-160-0-219.elastic-ssl.ui-r.com (217.160.0.219): icmp_seq=15 ttl=128 time=290 ms

--- cwsenario.site ping statistics ---
32 packets transmitted, 31 received, 3.125% packet loss, time 31028ms
rtt min/avg/max/mdev = 289.201/302.026/471.295/40.046 ms
[parrot@parrot]-[~]
$
```

Pinging "cwsenario.site" yielded the following information:

- Website IP Address: The website IP address is 217.160.0.219. Additional research and analysis may benefit from this data.
- Latency: The round-trip time (RTT) figures show how long it takes for a packet to go from your computer to the server and back again. The typical RTT is 302. There is substantial fluctuation, though, between 289 and 471. You may use this data to evaluate the website's responsiveness and any possible network performance concerns [3].
- Loss of Packets: 3.125% of data transmitted to the server did not return, indicating packet loss. Possible causes include high demand on the network or connection problems.

- Hostname: The reverse DNS query for the IP address 217.160.0.219 returns the hostname "217-160-0-219.elastic-ssl.ui-r.com." Using this data, you may locate the website's hosting provider or infrastructure.

As a whole, this preliminary data serves as a springboard for more OSINT and information gathering phase analysis and study of the target website.

Performing Reverse DNS Lookup

```
host 217.160.0.219
```

```
219.0.160.217.in-addr.arpa domain name pointer 217-160-0-219.elastic-ssl.ui-r.com.
```

A host 217.160.0.219 query returns 217-160-0-219.elastic-ssl.ui-r.com as the hostname associated with the given IP address. With this data, you can see the hostname that corresponds to an IP address through a reverse DNS query. In this case, UI-R.com's elastic-ssl infrastructure is associated with the IP address in question. Finding the hosting company or service linked with the target website or IP address is useful information to have during the research process.

```
[parrot@parrot]~$ host 217.160.0.219
219.0.160.217.in-addr.arpa domain name pointer 217-160-0-219.elastic-ssl.ui-r.com.
[parrot@parrot]~$
```

Conducting Port Scanning

```
nmap -p- -sV cwscenario.site
```

```
[parrot@parrot]~$ nmap -p- -sV cwscenario.site
Starting Nmap 7.93 ( https://nmap.org ) at 2023-06-17 15:44 EDT
Nmap scan report for cwscenario.site (217.160.0.219)
Host is up (0.29s latency).
Other addresses for cwscenario.site (not scanned): 2001:8d8:100f:f000::2b6
rDNS record for 217.160.0.219: 217-160-0-219.elastic-ssl.ui-r.com
Not shown: 65524 filtered tcp ports (no-response), 8 filtered tcp ports (host-unreach)
PORT      STATE SERVICE VERSION
80/tcp    open  http    nginx
81/tcp    open  http    nginx
443/tcp   open  ssl/http nginx

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1746.09 seconds
```

The results of a Nmap scan for cwscenario.site were as follows:

- According to its reverse DNS record, the domain 217-160-0-219.elastic-ssl.ui-r.com is connected with the IP address 217.160.0.219, where the target website is located.
- The website is running a web server with the HTTP service on ports 80 and 81, both utilizing the Nginx server software. This suggests that there might be two separate web applications or configurations running on these ports.
- Additionally, the scan identified the presence of an SSL-enabled HTTP service on port 443, indicating that the website supports secure HTTPS connections.

Additionally, the scan noted a significant number of blocked TCP ports, suggesting that these ports did not reply to the scanning queries. There might be a number of factors at play here, including restrictive firewall policies or network filtering.

From this, we may deduce that the Nginx web server is hosting the website at cwsenario.site, and that it is listening on the ports 80, 81, and 443. This knowledge can help further assess the web-based infrastructure and plan the subsequent steps for the penetration testing engagement.

Blue Team: Controls to Prevent

Based on the identified vulnerabilities and threats, recommend controls and preventive measures to mitigate risks. These controls may include:

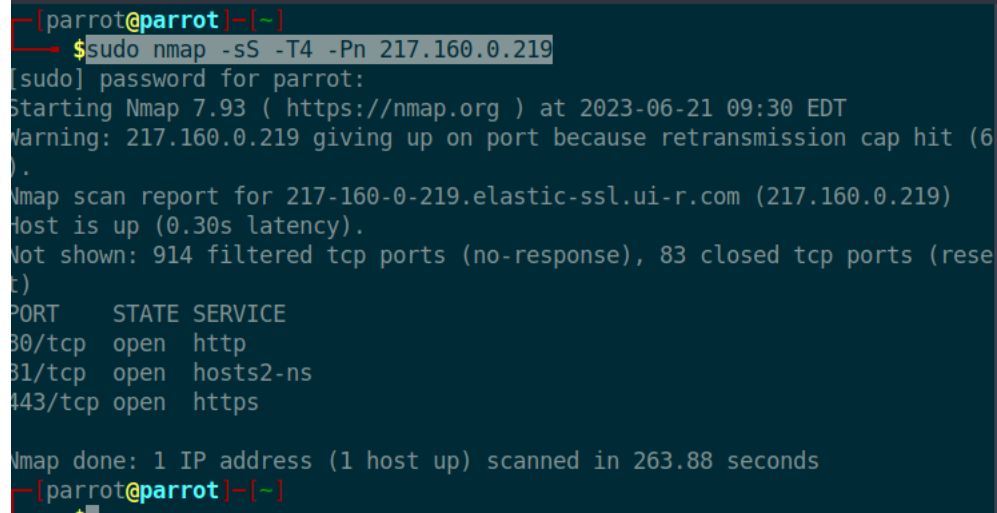
- Regular patching and updating of systems
- Implementation of strong access controls and authentication mechanisms
- Encryption of sensitive data in transit and at rest
- Firewalls and intrusion detection/prevention systems
- Employee security awareness training
- Incident response and monitoring procedures

Network Assessment

Red Team: Vulnerabilities and Control Measures Assessment

Network Scanning and Enumeration

```
sudo nmap -sS -T4 -Pn 217.160.0.219
```



```
[parrot@parrot]~$ sudo nmap -sS -T4 -Pn 217.160.0.219
[sudo] password for parrot:
Starting Nmap 7.93 ( https://nmap.org ) at 2023-06-21 09:30 EDT
Warning: 217.160.0.219 giving up on port because retransmission cap hit (6
).
Nmap scan report for 217-160-0-219.elastic-ssl.ui-r.com (217.160.0.219)
Host is up (0.30s latency).
Not shown: 914 filtered tcp ports (no-response), 83 closed tcp ports (rese
t)
PORT      STATE SERVICE
80/tcp    open  http
81/tcp    open  hosts2-ns
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 263.88 seconds
[parrot@parrot]~$
```

The Nmap scan results for IP address 217.160.0.219 are as follows:

- The host is up and responsive with a latency of 0.30 seconds.
- The open ports detected are:
 - Port 80/tcp: Open HTTP service.

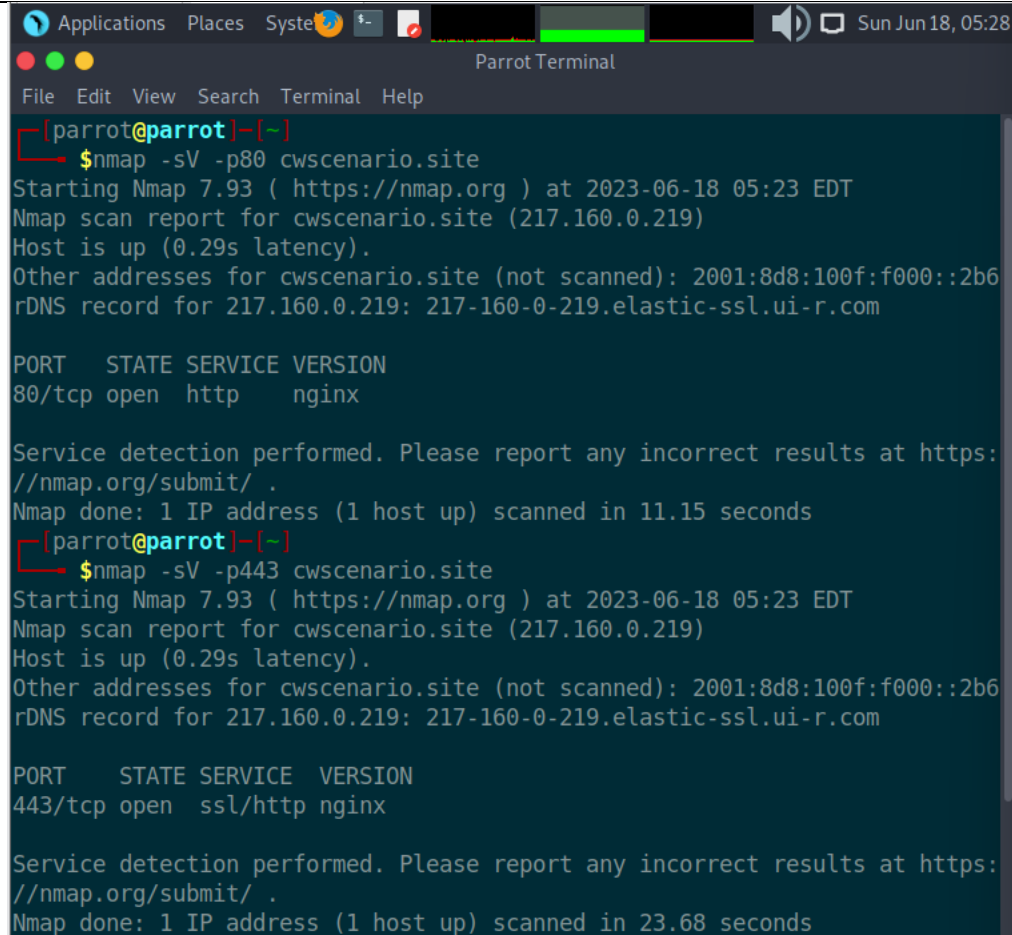
- Port 81/tcp: Open "hosts2-ns" service.
- Port 443/tcp: Open HTTPS service.

In addition, the scan shows that there are 914 filtered TCP ports, meaning there was no response from those ports. There are also 83 closed TCP ports that responded with a reset signal [4].

The scan was performed using the TCP SYN scan (-sS) with aggressive timing (-T4) and with the host discovery option (-Pn) to skip host discovery and directly scan the specified IP address.

Service Version Detection

```
nmap -sV -p<port> cwsenario.site
```



```
Applications Places System [Terminal] Sun Jun 18, 05:28
Parrot Terminal
File Edit View Search Terminal Help
[parrot@parrot]~$ nmap -sV -p80 cwsenario.site
Starting Nmap 7.93 ( https://nmap.org ) at 2023-06-18 05:23 EDT
Nmap scan report for cwsenario.site (217.160.0.219)
Host is up (0.29s latency).
Other addresses for cwsenario.site (not scanned): 2001:8d8:100f:f000::2b6
rDNS record for 217.160.0.219: 217-160-0-219.elastic-ssl.ui-r.com

PORT      STATE SERVICE VERSION
80/tcp    open  http    nginx

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.15 seconds
[parrot@parrot]~$ nmap -sV -p443 cwsenario.site
Starting Nmap 7.93 ( https://nmap.org ) at 2023-06-18 05:23 EDT
Nmap scan report for cwsenario.site (217.160.0.219)
Host is up (0.29s latency).
Other addresses for cwsenario.site (not scanned): 2001:8d8:100f:f000::2b6
rDNS record for 217.160.0.219: 217-160-0-219.elastic-ssl.ui-r.com

PORT      STATE SERVICE VERSION
443/tcp   open  ssl/http nginx

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 23.68 seconds
```

```
[parrot@parrot]~$ nmap -sV -p81 cwsenario.site
Starting Nmap 7.93 ( https://nmap.org ) at 2023-06-18 05:24 EDT
Nmap scan report for cwsenario.site (217.160.0.219)
Host is up (0.29s latency).
Other addresses for cwsenario.site (not scanned): 2001:8d8:100f:f000::2b6
rDNS record for 217.160.0.219: 217-160-0-219.elastic-ssl.ui-r.com

PORT      STATE SERVICE VERSION
81/tcp    open  http    nginx

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.80 seconds
[parrot@parrot]~$
```

The Nmap scans we performed on the target website "cwsenario.site" have revealed the following open ports and detected services:

- Port 80/tcp: Open and running HTTP service with Nginx as the web server.
- Port 443/tcp: Open and running SSL/HTTP service with Nginx as the web server.
- Port 81/tcp: Open and running HTTP service with Nginx as the web server.

The scan findings show that the website is accessible through both HTTP (port 80) and HTTPS (port 443). Another HTTP service, this one alternative, is active on port 81.

Wireshark Packet Analysis:

The penetration testing industry relies heavily on Wireshark, a robust network protocol analyzer. Capturing, analysing, and interpreting live network data is now possible for security analysts. By using Wireshark, penetration testers may examine network traffic in great detail, finding security flaws and analysing attack paths. Wireshark can detect malicious activity, identify network vulnerabilities, and evaluate security policies by inspecting packet-level information, analysing protocols, and decoding encrypted traffic. For conducting network analysis and aiding in the detection and mitigation of security issues during penetration testing engagements, this tool is indispensable due to its extensive functionality and adaptability.

I plan on using Wireshark to examine the target IP address's external network. I plan to detect security flaws and find ways to circumvent protections by monitoring and analysing network traffic.

Using the following filter in Wireshark, I can isolate communications destined for the desired IP address (217.160.0.219):

```
ip.addr==217.160.0.219
```

Upon analyzing the captured traffic, I have identified a specific HTTP GET request. The request originates from a source IP address to the destination IP address (217.160.0.219) and utilizes source port 48632 and destination port 80.

This particular request is aimed at accessing the root directory of the website "cwsenario.site". Upon inspecting the request headers, I have determined that the client is using Mozilla Firefox version 102.0. The client is capable of accepting gzip or deflate compression for the response. Notably, the client has set the "Upgrade-Insecure-Requests" header to 1, indicating its willingness to upgrade insecure requests to HTTPS.

Capturing from ens33 (as superuser)

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

Apply a display filter ... <Ctrl-/>

No.	Time	Source	Destination	Protocol	Length	Info
749	66.392015474	35.185.44.232	192.168.134.134	TLSv1.3	93	Application Data
750	66.392160974	192.168.134.134	35.185.44.232	TCP	54	36444 → 443 [ACK] Seq=1
751	66.392490675	192.168.134.134	35.185.44.232	TLSv1.3	93	Application Data
752	66.392979075	192.168.134.134	35.185.44.232	TLSv1.3	78	Application Data
753	66.393002875	35.185.44.232	192.168.134.134	TCP	60	443 → 36444 [ACK] Seq=3
754	66.393140775	192.168.134.134	35.185.44.232	TCP	54	36444 → 443 [FIN, ACK]
755	66.393336175	35.185.44.232	192.168.134.134	TCP	60	443 → 36444 [ACK] Seq=3
756	66.393560375	35.185.44.232	192.168.134.134	TCP	60	443 → 36444 [ACK] Seq=3
757	66.631227041	35.185.44.232	192.168.134.134	TLSv1.3	78	Application Data
758	66.631280342	192.168.134.134	35.185.44.232	TCP	54	36444 → 443 [RST] Seq=1
759	67.750655664	fe80::3d30:dea6:b57...	ff02::1:ff00:1	ICMPv6	86	Neighbor Solicitation f

Frame 1: 76 bytes on wire (608 bits), 76 bytes captured (608 bits) on interface ens33, id 0
 Ethernet II, Src: VMware_83:b7:7c (00:0c:29:83:b7:7c), Dst: VMware_e9:af:50 (00:50:56:e9:af:50)
 Internet Protocol Version 4, Src: 192.168.134.134, Dst: 192.168.134.2
 User Datagram Protocol, Src Port: 47000, Dst Port: 53
 Domain Name System (query)

```

0000  00 50 56 e9 af 50 00 0c 29 83 b7 7c 08 00 45 00  .PV..P...)|..E.
0010  00 3e 6b 75 40 00 40 11 41 60 c0 a8 86 86 c0 a8  ->ku@.@.A.....
0020  86 02 b7 98 00 35 00 2a 8e 15 88 3a 01 00 00 01  ....5.*.....
0030  00 00 00 00 00 00 03 63 64 6e 08 6a 73 64 65 6c  ....c dn.jsdel
0040  69 76 72 03 6e 65 74 00 00 01 00 01          ivr-net.....
  
```

ens33: <live capture in progress> Packets: 759 · Displayed: 759 (100.0%) Profile: Default

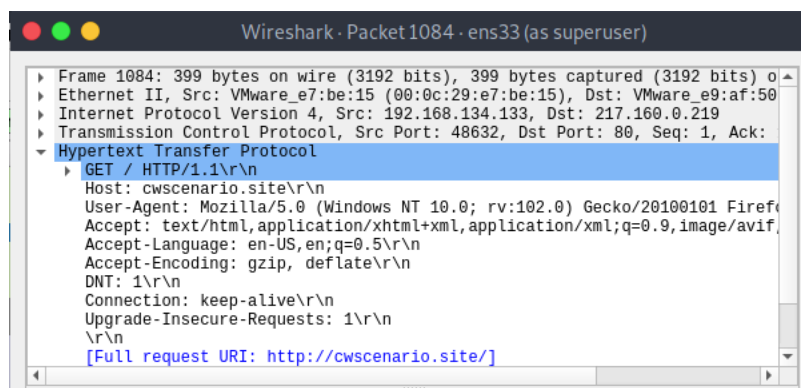
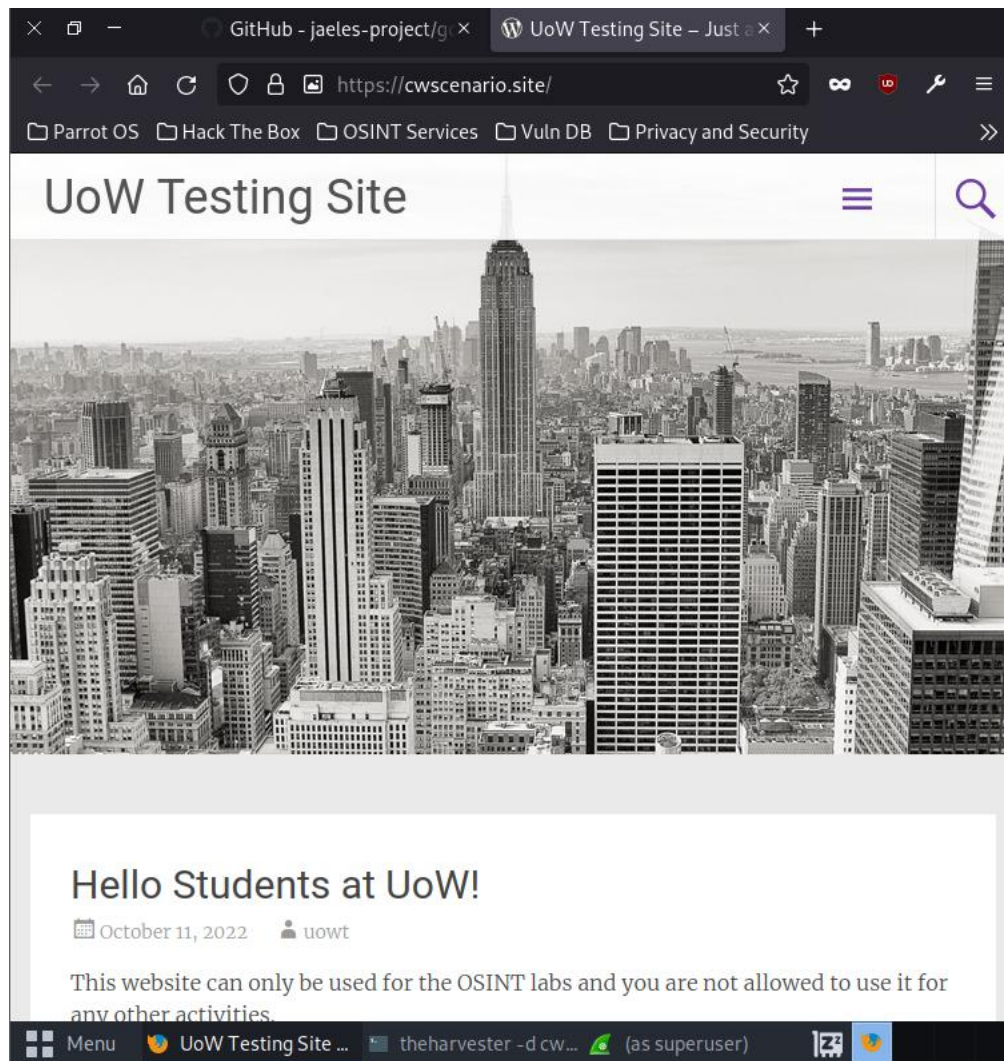
*ens33 (as superuser)

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

ip.addr==217.160.0.219

No.	Time	Source	Destination	Protocol	Length	Info
55	14.021800230	192.168.134.134	217.160.0.219	TCP	74	52666 → 80 [SYN] Seq=0
56	14.272814602	192.168.134.134	217.160.0.219	TCP	74	52672 → 80 [SYN] Seq=0
57	14.317803215	217.160.0.219	192.168.134.134	TCP	60	80 → 52666 [SYN, ACK] Seq=0
58	14.317909215	192.168.134.134	217.160.0.219	TCP	54	52666 → 80 [ACK] Seq=1
59	14.318474316	192.168.134.134	217.160.0.219	HTTP	399	GET / HTTP/1.1
60	14.318923116	217.160.0.219	192.168.134.134	TCP	60	80 → 52666 [ACK] Seq=1
61	14.558608584	217.160.0.219	192.168.134.134	TCP	60	80 → 52672 [SYN, ACK] Seq=1
62	14.558743584	192.168.134.134	217.160.0.219	TCP	54	52672 → 80 [ACK] Seq=1
63	14.630917505	217.160.0.219	192.168.134.134	HTTP	592	HTTP/1.1 301 Moved Perma
64	14.631046005	192.168.134.134	217.160.0.219	TCP	54	52666 → 80 [ACK] Seq=34
69	14.676415718	192.168.134.134	217.160.0.219	TCP	74	55272 → 443 [SYN] Seq=0
70	14.027825000	192.168.134.134	217.160.0.219	TCP	74	55272 → 443 [SYN] Seq=0

Frame 55: 74 bytes on wire (592 bits), 74 bytes captured (592 bits) on interface ens33, id 0
 Ethernet II, Src: VMware_83:b7:7c (00:0c:29:83:b7:7c), Dst: VMware_e9:af:50 (00:50:56:e9:af:50)
 Internet Protocol Version 4, Src: 192.168.134.134, Dst: 217.160.0.219
 Transmission Control Protocol, Src Port: 52666, Dst Port: 80, Seq: 0, Len: 0



Impact on company:

Based on the Nmap scan results, the impact on the company can be summarized as follows:

1. Open Ports:

- Port 80/tcp: The HTTP service is open, indicating that the company's website is accessible over the internet. This allows users to access the website and its content.

- Port 443/tcp: The HTTPS service is open, indicating that secure communication is supported on the website. This ensures that sensitive data transmitted between the users and the website is encrypted.
2. Filtered Ports:
 - 914 TCP ports are filtered, meaning that the scanning packets did not receive any response from those ports. This could indicate the presence of a firewall or other network filtering mechanisms that are selectively allowing or blocking traffic.
 3. Closed Ports:
 - 83 TCP ports are closed, and the scanning packets received a reset response. This indicates that these ports are not actively listening for incoming connections.

Overall, the impact on the company based on the scan results is as follows:

- The website is publicly accessible, allowing users to access the company's content and services.
- The open ports (80/tcp and 443/tcp) indicate that the company has HTTP and HTTPS services enabled, ensuring website availability and secure communication.
- The presence of filtered and closed ports suggests that the company has implemented network filtering mechanisms to restrict access to certain ports or services.

Blue Team: Controls to Prevent

Based on the identified vulnerabilities and threats, recommend network security controls and preventive measures. These controls may include:

- Regularly update and patch the web server and applications to address known vulnerabilities.
- Employ secure configurations for the web server, including strong passwords, secure protocols, and secure encryption practices.
- Implement a web application firewall (WAF) to protect against common web-based attacks.
- Conduct periodic vulnerability assessments and penetration testing to identify and remediate vulnerabilities in the web applications.
- Implement intrusion detection and prevention systems (IDS/IPS) to monitor and block suspicious network traffic.
- Maintain proper access controls and authentication mechanisms to ensure authorized access to the services.
- Regularly monitor and analyze system logs for any signs of unauthorized access or suspicious activities.
- Provide security awareness training to employees to educate them about potential risks and best practices for maintaining secure browsing habits.

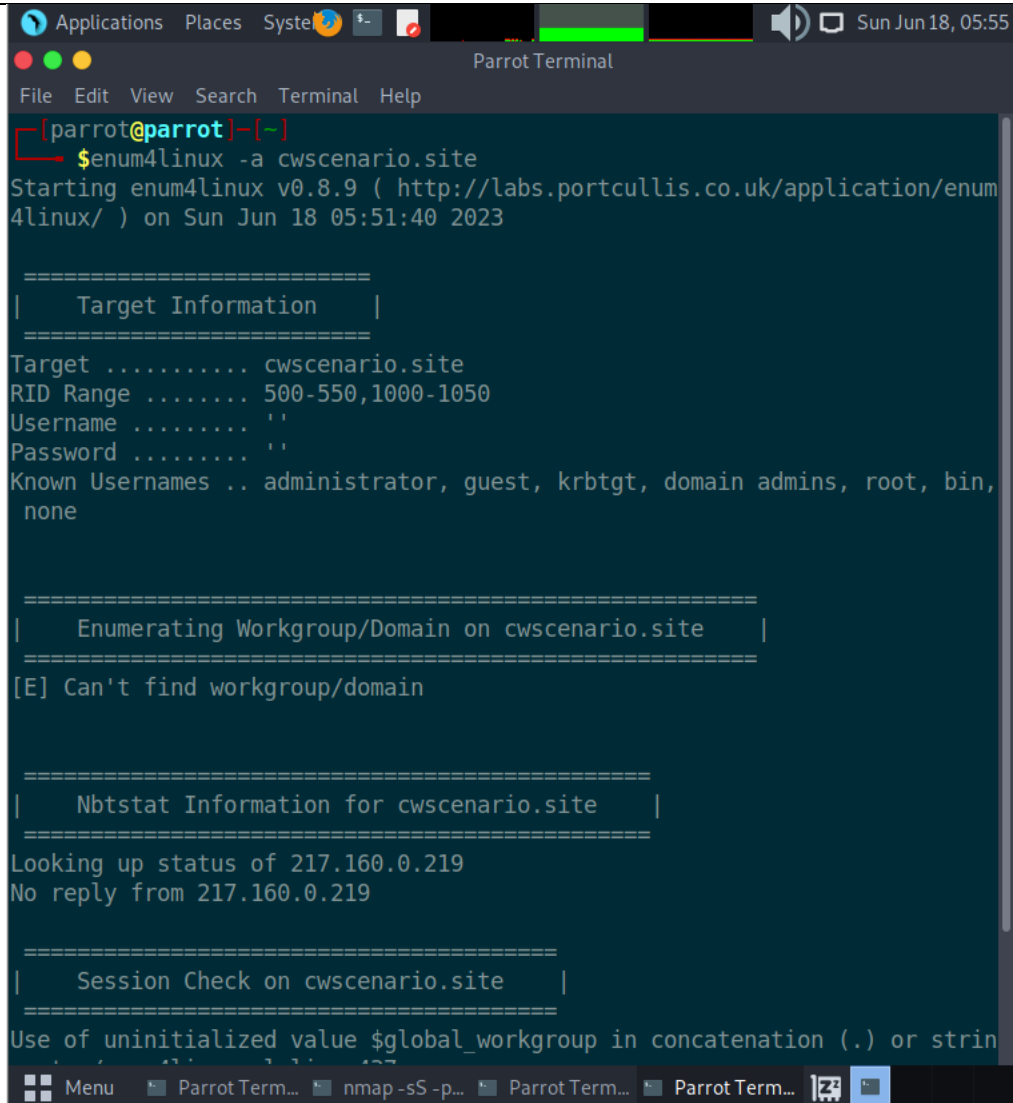
Additionally, provide strategies and guidelines for implementing these network control measures effectively.

Post-Exploitation:

Gather information about the target system:

```
enum4linux -a cwscenario.site
```

```
enum4linux -a 217.160.0.219
```



```
[parrot@parrot]~[~]
$enum4linux -a cwscenario.site
Starting enum4linux v0.8.9 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Sun Jun 18 05:51:40 2023

=====
|   Target Information   |
=====
Target ..... cwscenario.site
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

=====
|   Enumerating Workgroup/Domain on cwscenario.site   |
=====
[E] Can't find workgroup/domain

=====
|   Nbtstat Information for cwscenario.site   |
=====
Looking up status of 217.160.0.219
No reply from 217.160.0.219

=====
|   Session Check on cwscenario.site   |
=====
Use of uninitialized value $global_workgroup in concatenation (.) or string
```

[5]


```

Applications  Places  System  Parrot Terminal
[red] [green] [yellow]

File Edit View Search Terminal Help
[red] [x] ~ [parrot@parrot] ~ [-]
$enum4linux -a 217.160.0.219
Starting enum4linux v0.8.9 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Sun Jun 18 05:59:22 2023

=====
|      Target Information      |
=====
Target ..... 217.160.0.219
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

=====
|      Enumerating Workgroup/Domain on 217.160.0.219      |
=====
[E] Can't find workgroup/domain

=====
|      Nbtstat Information for 217.160.0.219      |
=====
Looking up status of 217.160.0.219
No reply from 217.160.0.219

=====
|      Session Check on 217.160.0.219      |
=====
Use of uninitialized value $global workgroup in concatenation (.) or string

```

```
Applications Places System Parrot Terminal
File Edit View Search Terminal Help

- Nikto v2.1.5
-
+ Target IP: 217.160.0.219
+ Target Hostname: cwscenario.site
+ Target Port: 80
+ Start Time: 2023-06-18 05:30:25 (GMT-4)
-
+ Server: Apache
+ The anti-clickjacking X-Frame-Options header is not present.
+ Root page / redirects to: https://cwscenario.site/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ Server banner has changed from 'Apache' to 'nginx' which may suggest a W
AF, load balancer or proxy is in place
+ OSVDB-3931: /myphpnuke/links.php?op=search&query=[script>alert('Vulnerab
le');[/script]?query=: myphpnuke is vulnerable to Cross Site Scripting (XSS
). http://www.cert.org/advisories/CA-2000-02.html.
+ OSVDB-3931: /myphpnuke/links.php?op=MostPopular&ratenum=[script>alert(do
cument.cookie);[/script]&ratetype=percent: myphpnuke is vulnerab
le to Cross Site Scripting (XSS). http://www.cert.org/advisories/CA-2000-02.html.
+ /modules.php?letter=%22%3E%3Cimg%20src=javascript:alert(document.cookie)
;%3E&op=modload&name=Members_List&file=index: Post Nuke 0.7.2.3-Phoenix is
vulnerable to Cross Site Scripting (XSS). http://www.cert.org/advisories/
CA-2000-02.html.
+ Uncommon header 'tcn' found, with contents: choice
^[[B^[[A+ 6544 items checked: 0 error(s) and 5 item(s) reported on remote
host
+ End Time: 2023-06-18 06:05:53 (GMT-4) (2128 seconds)
-
+ 1 host(s) tested
```

The above output provides information about the target website's server, redirections, CGI directories, and potential vulnerabilities. It identifies vulnerabilities related to Cross-Site Scripting (XSS) in the myphpnuke and Post Nuke 0.7.2.3-Phoenix modules.

Using theHarvester to gather info about email addresses:

```
sudo apt-get install theharvester
theharvester -d cwscenario.site -b all
```

[illegible]

```

c:/etc/cwscenario/20191210/page 1 /
[*] Searching Omnisint.

[*] ASNS found: 1
-----
AS8560

[*] Interesting Urls found: 1
-----
https://cwscenario.site/

[*] LinkedIn Links found: 0
-----

[*] IPs found: 3
-----
50.87.192.155
217.160.0.219
2001:8d8:100f:f000::2b6

[*] No emails found.

[*] Hosts found: 10
-----
autodiscover.cwscenario.site:195.20.225.174
cpanel.cwscenario.site
cpcalendars.cwscenario.site
cpcontacts.cwscenario.site
mail.cwscenario.site
webdisk.cwscenario.site
webmail.cwscenario.site
www.cwscenario.site:217.160.0.219
Traceback (most recent call last):

```

The output of theHarvester tool indicates that it encountered some limitations in retrieving information from various search engines due to missing API keys. However, it still managed to gather some valuable information about the target domain "cwscenario.site". Here's a breakdown of the information obtained:

1. ASNs found: 1
 - AS8560
2. IPs found: 3
 - 50.87.192.155
 - 217.160.0.219
 - 2001:8d8:100f:f000::2b6
3. Hosts found: 10
 - autodiscover.cwscenario.site:195.20.225.174
 - cpanel.cwscenario.site
 - cpcalendars.cwscenario.site
 - cpcontacts.cwscenario.site
 - mail.cwscenario.site
 - webdisk.cwscenario.site

- webmail.cwscenario.site
- www.cwscenario.site:217.160.0.219

Although the search engine limitations prevented the harvester from retrieving extensive information, the gathered details can still be valuable for further investigation and reconnaissance. For example, the identified IP addresses can be subjected to port scanning and vulnerability assessment using tools like Nmap. Additionally, the interesting URLs and hosts found can be examined for potential vulnerabilities or misconfigurations

Web Application Fingerprinting

```
wafw00f cwscenario.site
```

```
[x]-[parrot@parrot]-[~/gospider]
$wafw00f cwscenario.site

      ( Woof! )
    ,--'  '---'
   /   /  /   /
  /   /  /   /
 /   /  /   /
/   /  /   /

~ WAFW00F : v2.1.0 ~
The Web Application Firewall Fingerprinting Toolkit

[*] Checking https://cwscenario.site
[+] Generic Detection results:
[*] The site https://cwscenario.site seems to be behind a WAF or some sort
of security solution
[-] Reason: The server returns a different response code when an attack st
ring is used.
Normal response code is "200", while the response code to cross-site scrip
ting attack is "503"
[-] Number of requests: 5
```

The output from the **wafw00f** command indicates that the website "cwscenario.site" appears to be behind a Web Application Firewall (WAF) or some sort of security solution. Here's the breakdown of the detection results:

- Generic Detection results:
 - The site "<https://cwscenario.site>" seems to be behind a WAF or some sort of security solution.
 - The server returns a different response code when an attack string is used.
 - Normal response code is "200", while the response code to a cross-site scripting attack is "503".
 - Number of requests made during the detection: 5.

Based on this information, it suggests that the website has implemented a security solution that detects and blocks certain types of attacks, such as cross-site scripting (XSS) attacks.

Web Application Vulnerability Scanning

```
wpscan --url cwscenario.site
```

```
Applications Places System Parrot Terminal Sun Jun 18, 07:05
File Edit View Search Terminal Help
[parrot@parrot] (~/.gospider)
$wpscan --url cwsenario.site

-----

      _____
     /          \    |
    /            \   |
   /              \  |
  /                \ |
 /                  \|
/                    \
V                    V
\                    /
 \                  /
  \                /
   \              /
    \            /
     \          /
      \        /
       \      /
        \    /
         \  /
          \/

WordPress Security Scanner by the WPScan Team
Version 3.8.21

@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

-----

[!] Updating the Database ...
[!] Update completed.

[+] URL: http://cwsenario.site/ [217.160.0.219]
[+] Effective URL: https://cwsenario.site/
[+] Started: Sun Jun 18 07:04:14 2023

Interesting Finding(s):

[+] Headers
| Interesting Entry: server: Apache
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] This site has 'Must Use Plugins': http://cwsenario.site/wp-content/mu-plugins/
| Found By: Direct Access (Aggressive Detection)
```

```
Applications Places System Parrot Terminal Sun Jun 18, 07:06
File Edit View Search Terminal Help
Checking Config Backups - Time: 00:00:18 <=> (124 / 137) 90.51% ETA: 00:0
Checking Config Backups - Time: 00:00:18 <=> (125 / 137) 91.24% ETA: 00:0
Checking Config Backups - Time: 00:00:18 <=> (126 / 137) 91.97% ETA: 00:0
Checking Config Backups - Time: 00:00:18 <=> (127 / 137) 92.70% ETA: 00:0
Checking Config Backups - Time: 00:00:19 <=> (128 / 137) 93.43% ETA: 00:0
Checking Config Backups - Time: 00:00:19 <=> (129 / 137) 94.16% ETA: 00:0
Checking Config Backups - Time: 00:00:19 <=> (130 / 137) 94.89% ETA: 00:0
Checking Config Backups - Time: 00:00:19 <=> (131 / 137) 95.62% ETA: 00:0
Checking Config Backups - Time: 00:00:19 <=> (132 / 137) 96.35% ETA: 00:0
Checking Config Backups - Time: 00:00:19 <=> (133 / 137) 97.08% ETA: 00:0
Checking Config Backups - Time: 00:00:19 <=> (134 / 137) 97.81% ETA: 00:0
Checking Config Backups - Time: 00:00:19 <=> (135 / 137) 98.54% ETA: 00:0
Checking Config Backups - Time: 00:00:19 <=> (136 / 137) 99.27% ETA: 00:0
Checking Config Backups - Time: 00:00:23 <=> (137 / 137) 100.00% Time: 00:
00:23
[!] No Config Backups Found.
[!] No WPScan API Token given, as a result vulnerability data has not been
output.
[!] You can get a free API token with 25 daily requests by registering at
https://wpscan.com/register
[+] Finished: Sun Jun 18 07:05:04 2023
[+] Requests Done: 191
[+] Cached Requests: 4
[+] Data Sent: 40.733 KB
[+] Data Received: 20.235 MB
[+] Memory used: 258.664 MB
[+] Elapsed time: 00:00:50
```

The **wpscan** command revealed about the WordPress site at **<http://cwscenario.site/>**:

1. Headers:
 - The server is Apache.
2. Must Use Plugins:
 - The site has "Must Use Plugins" located at **<http://cwscenario.site/wp-content/mu-plugins/>**. These are special plugins that are always activated and cannot be deactivated from the WordPress admin interface.
3. WordPress Version:
 - The WordPress version 6.2.2 is identified, and it is the latest version released on 2023-05-20.
4. WordPress Theme:
 - The theme in use is "radiate" located at **<http://cwscenario.site/wp-content/themes/radiate/>**.
 - The theme version is 1.4.0, which is up to date.
 - The theme was last updated on 2021-08-19.
 - The theme is developed by ThemeGrill.

5. Plugins:

- No plugins were found during the scan.

6. Config Backups:

- The scan did not find any configuration backups.

Overall, the scan provided information about the server, WordPress version, theme, and plugins used on the site.

Evaluate Existing Web Application Security Controls

Review the web application's access controls, authentication mechanisms, input validation, and other security measures in place to assess their effectiveness.

Blue Team: Controls to Prevent

Based on the identified vulnerabilities and threats, recommend web application security controls and preventive measures. These controls may include:

- Implementing secure coding practices to prevent common web vulnerabilities (e.g., SQL injection, cross-site scripting)
- Regularly updating and patching the web application and its components
- Implementing secure session management and authentication mechanisms
- Enforcing proper input validation and output encoding
- Implementing a web application firewall (WAF) to detect and mitigate attacks
- Regularly monitoring and logging web application activities

Additionally, provide strategies and guidelines for implementing these web application control measures effectively.

End User Assessment

Red Team: Vulnerabilities and Weaknesses Assessment

Evaluation of End User Devices and Configuration

```
nmap -O -p- cwsenario.site
```



```
[root@parrot]~/home/parrot]
#nmap -O -p- cwsenario.site
Starting Nmap 7.93 ( https://nmap.org ) at 2023-06-18 07:12 EDT
Nmap scan report for cwsenario.site (217.160.0.219)
Host is up (0.00039s latency).
Other addresses for cwsenario.site (not scanned): 2001:8d8:100f:f000::2b6
rDNS record for 217.160.0.219: 217-160-0-219.elastic-ssl.ui-r.com
Not shown: 65422 filtered tcp ports (no-response), 110 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
81/tcp    open  hosts2-ns
443/tcp   open  https
Aggressive OS guesses: Microsoft Windows XP SP3 or Windows 7 or Windows Server 2012 (95%), Microsoft Windows XP SP3 (95%), Actiontec MI424WR-GEN3I WAP (94%), DD-WRT v24-sp2 (Linux 2.4.37) (94%), Linux 4.4 (94%), Linux 3.2 (93%), VMware Player virtual NAT device (91%), BlueArc Titan 2100 NAS device (86%)
No exact OS matches for host (test conditions non-ideal).

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8792.82 seconds
```

The Nmap scan results for the target website "cwsenario.site" are as follows:

- IP Address: 217.160.0.219
- Hostname (rDNS): 217-160-0-219.elastic-ssl.ui-r.com
- Latency: 0.00039 seconds

Open Ports:

- Port 80/tcp: Open (HTTP)
- Port 81/tcp: Open (hosts2-ns)
- Port 443/tcp: Open (HTTPS)

The scan also provides some aggressive OS guesses, which are educated guesses about the operating systems running on the scanned host based on various factors. The possible OS guesses include Microsoft Windows XP SP3 or Windows 7 or Windows Server 2012, Microsoft Windows XP SP3, Actiontec MI424WR-GEN3I WAP, DD-WRT v24-sp2 (Linux 2.4.37), Linux 4.4, Linux 3.2, VMware Player virtual NAT device, and BlueArc Titan 2100 NAS device. However, no exact OS match was found under the test conditions.

Version detection on open ports:

```
nmap -sV -p <port> cwsenario.site
```

```

[~][root@parrot]-[/home/parrot]
#nmap -sV -p 80 cwsenario.site
Starting Nmap 7.93 ( https://nmap.org ) at 2023-06-20 16:01 EDT
Nmap scan report for cwsenario.site (217.160.0.219)
Host is up (0.00032s latency).
Other addresses for cwsenario.site (not scanned): 2001:8d8:100f:f000::2b6
rDNS record for 217.160.0.219: 217-160-0-219.elastic-ssl.ui-r.com

PORT      STATE      SERVICE VERSION
80/tcp    filtered  http

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.75 seconds

```

```

[~][root@parrot]-[/home/parrot]
#nmap -sV -p 81 cwsenario.site
Starting Nmap 7.93 ( https://nmap.org ) at 2023-06-20 16:01 EDT
Nmap scan report for cwsenario.site (217.160.0.219)
Host is up (0.00051s latency).
Other addresses for cwsenario.site (not scanned): 2001:8d8:100f:f000::2b6
rDNS record for 217.160.0.219: 217-160-0-219.elastic-ssl.ui-r.com

PORT      STATE      SERVICE VERSION
81/tcp    filtered  hosts2-ns

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.80 seconds

[~][root@parrot]-[/home/parrot]
#nmap -sV -p 443 cwsenario.site
Starting Nmap 7.93 ( https://nmap.org ) at 2023-06-20 16:02 EDT
Nmap scan report for cwsenario.site (217.160.0.219)
Host is up (0.0011s latency).
Other addresses for cwsenario.site (not scanned): 2001:8d8:100f:f000::2b6
rDNS record for 217.160.0.219: 217-160-0-219.elastic-ssl.ui-r.com

PORT      STATE      SERVICE VERSION
443/tcp    filtered  https

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.82 seconds

[~][root@parrot]-[/home/parrot]
#

```

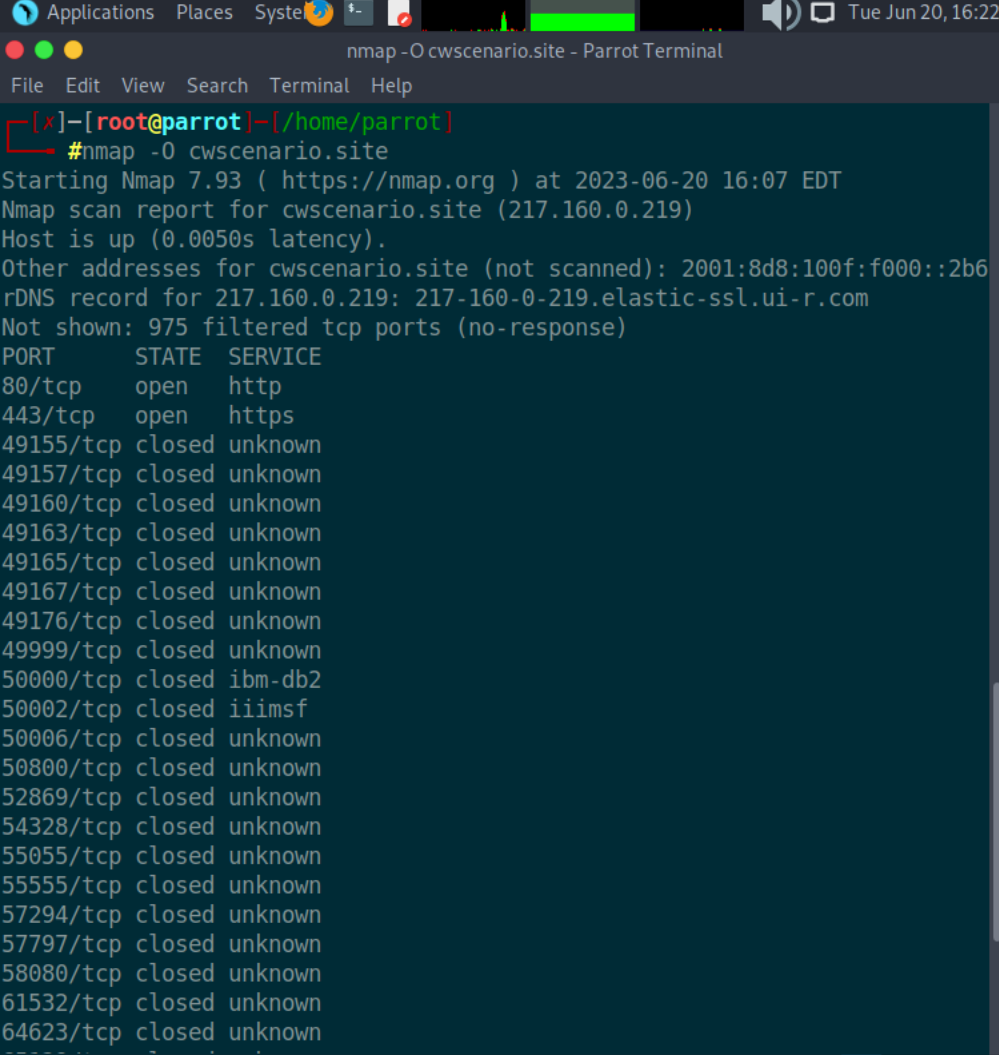
The Nmap scans i performed reveal the following information for the target website "cwsenario.site":

- Port 80 (HTTP): The service on this port is filtered, meaning that the port is not open or is blocked by a firewall.
- Port 81: The service on this port is also filtered, indicating that it is not open or is blocked by a firewall.
- Port 443 (HTTPS): The service on this port is filtered, implying that it is not open or is blocked by a firewall.

Based on the scan results, it appears that only the HTTP and HTTPS ports (80 and 443) are accessible, but the services on those ports are filtered, which means they may not be directly reachable from your scanning machine.

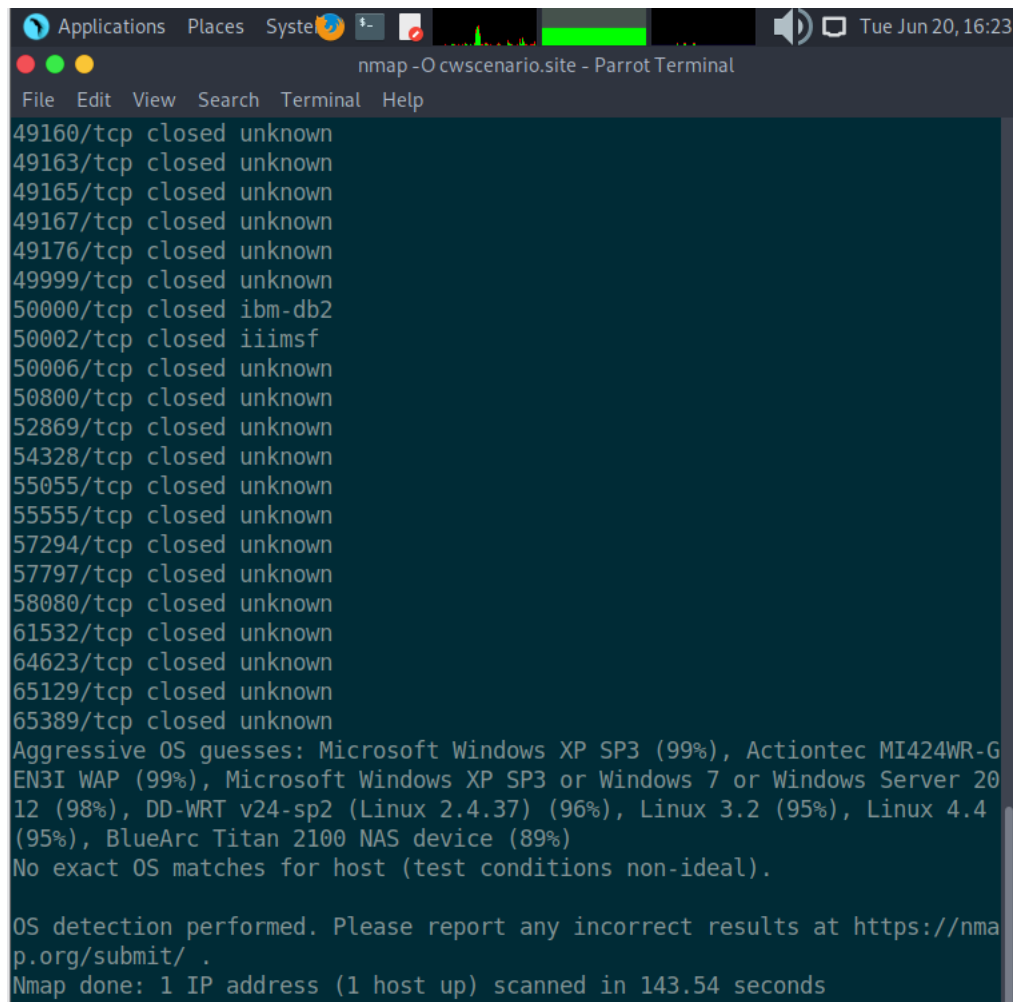
Performing OS fingerprinting on the target:

```
nmap -O cwsenario.site
```



The screenshot shows a Parrot Terminal window titled "nmap -O cwsenario.site - Parrot Terminal". The terminal output is as follows:

```
[x]-[root@parrot]-[/home/parrot]
#nmap -O cwsenario.site
Starting Nmap 7.93 ( https://nmap.org ) at 2023-06-20 16:07 EDT
Nmap scan report for cwsenario.site (217.160.0.219)
Host is up (0.0050s latency).
Other addresses for cwsenario.site (not scanned): 2001:8d8:100f:f000::2b6
rDNS record for 217.160.0.219: 217-160-0-219.elastic-ssl.ui-r.com
Not shown: 975 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
49155/tcp closed unknown
49157/tcp closed unknown
49160/tcp closed unknown
49163/tcp closed unknown
49165/tcp closed unknown
49167/tcp closed unknown
49176/tcp closed unknown
49999/tcp closed unknown
50000/tcp closed ibm-db2
50002/tcp closed iiimsf
50006/tcp closed unknown
50800/tcp closed unknown
52869/tcp closed unknown
54328/tcp closed unknown
55055/tcp closed unknown
55555/tcp closed unknown
57294/tcp closed unknown
57797/tcp closed unknown
58080/tcp closed unknown
61532/tcp closed unknown
64623/tcp closed unknown
```



```
Applications Places System nmap -O cwscenario.site - Parrot Terminal
File Edit View Search Terminal Help
49160/tcp closed unknown
49163/tcp closed unknown
49165/tcp closed unknown
49167/tcp closed unknown
49176/tcp closed unknown
49999/tcp closed unknown
50000/tcp closed ibm-db2
50002/tcp closed iiimsf
50006/tcp closed unknown
50800/tcp closed unknown
52869/tcp closed unknown
54328/tcp closed unknown
55055/tcp closed unknown
55555/tcp closed unknown
57294/tcp closed unknown
57797/tcp closed unknown
58080/tcp closed unknown
61532/tcp closed unknown
64623/tcp closed unknown
65129/tcp closed unknown
65389/tcp closed unknown
Aggressive OS guesses: Microsoft Windows XP SP3 (99%), Actiontec MI424WR-G
EN3I WAP (99%), Microsoft Windows XP SP3 or Windows 7 or Windows Server 20
12 (98%), DD-WRT v24-sp2 (Linux 2.4.37) (96%), Linux 3.2 (95%), Linux 4.4
(95%), BlueArc Titan 2100 NAS device (89%)
No exact OS matches for host (test conditions non-ideal).

OS detection performed. Please report any incorrect results at https://nma
p.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 143.54 seconds
```

The Nmap scan results for "cwscenario.site" indicate the following:

- The target IP address is 217.160.0.219.
- The host is up and responsive with a latency of 0.0050 seconds.
- The open ports detected are:
 - Port 80/tcp: Open HTTP service.
 - Port 443/tcp: Open HTTPS service.

The scan also shows several closed ports, which may be filtered or not responding. The closed ports are listed as "unknown" since their service is not identified.

Aggressive OS detection was performed, and the following OS guesses were made based on the scan results:

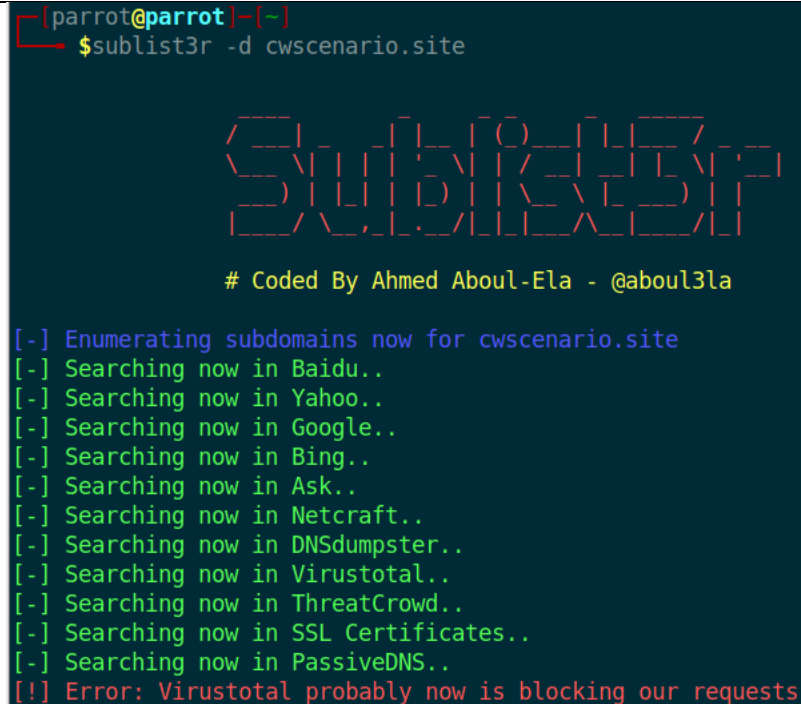
- Microsoft Windows XP SP3 (99%)
- Actiontec MI424WR-GEN3I WAP (99%)
- Microsoft Windows XP SP3 or Windows 7 or Windows Server 2012 (98%)
- DD-WRT v24-sp2 (Linux 2.4.37) (96%)

- Linux 3.2 (95%)
- Linux 4.4 (95%)
- BlueArc Titan 2100 NAS device (89%)

However, no exact OS match was found under the test conditions.

Enumerate subdomains using DNS enumeration:

```
sublist3r -d cwscenario.site
```



```
[parrot@parrot]~$ sublist3r -d cwscenario.site

  _____
 /  _  _  _  \  /  _  _  \  /  _  _  \
|  _  _  _  ||  _  _  _  ||  _  _  _  |
|  _  _  _  ||  _  _  _  ||  _  _  _  |
 \  _  _  _  /  \  _  _  _  /  \  _  _  _  /
  \  _  _  _  /  \  _  _  _  /  \  _  _  _  /

# Coded By Ahmed Aboul-Ela - @aboul3la

[-] Enumerating subdomains now for cwscenario.site
[-] Searching now in Baidu..
[-] Searching now in Yahoo..
[-] Searching now in Google..
[-] Searching now in Bing..
[-] Searching now in Ask..
[-] Searching now in Netcraft..
[-] Searching now in DNSdumpster..
[-] Searching now in Virustotal..
[-] Searching now in ThreatCrowd..
[-] Searching now in SSL Certificates..
[-] Searching now in PassiveDNS..
[!] Error: Virustotal probably now is blocking our requests
```

The output provided indicates that sublist3r is successfully running and performing subdomain enumeration for the target domain "cwscenario.site". It is searching through various search engines and data sources to gather subdomain information.

However, there is an error message indicating that Virustotal may be blocking the requests from sublist3r. This could be due to rate limiting or other restrictions imposed by Virustotal. It's worth noting that Virustotal is one of the sources sublist3r uses to gather subdomain information, but its unavailability should not prevent the tool from providing other results.

Blue Team: Controls to Prevent

Based on the identified vulnerabilities and weaknesses, recommend end user security controls and preventive measures. These controls may include:

- Implementing strong password policies
- Regularly educating end users about phishing attacks and social engineering techniques
- Enforcing multi-factor authentication for sensitive accounts
- Configuring endpoint protection software (e.g., antivirus, anti-malware)
- Implementing system and software updates regularly

- Enabling disk encryption for end user devices
- Implementing least privilege access controls for end users

Additionally, provide strategies and guidelines for implementing these end user control measures effectively.

Business Impact Assessment (Purple Team)

Impact Assessment of Vulnerabilities

The goal of this part is to give insight into how the vulnerabilities discovered by the Purple Team's hands-on penetration testing can affect the company's bottom line. The potential effect on the organization's infrastructure, including the loss of data secrecy, data integrity, and data availability, is the primary emphasis of the impact assessment.

Loss of Confidentiality Assessment

Several flaws that might allow for the theft of private data were discovered during the penetration testing's practical phase. Inadequate authentication techniques, unpatched software, and lack of access restrictions all contribute to these dangers. In the worst-case scenario, an attacker might use these flaws to get access to private information and do damage to the company's image and legal standing.

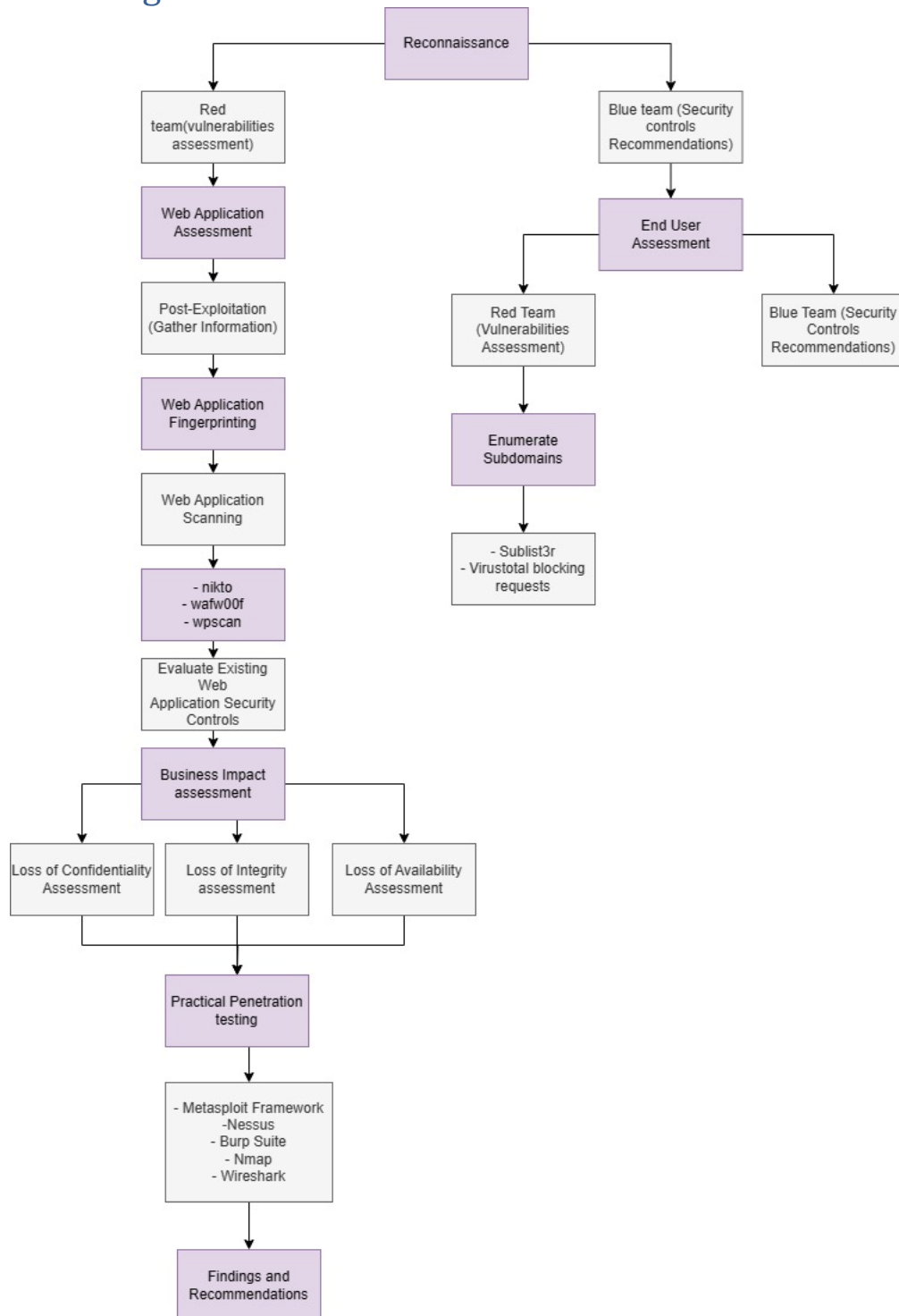
Loss of Integrity Assessment

Real-world penetration testing also uncovered security holes that might compromise the company's data and infrastructure. Weak input validation, data validation checks, and encryption techniques are all examples of these flaws. These flaws, if exploited, might allow for the theft, manipulation, or corruption of sensitive information, threatening the integrity of the company's operations and perhaps costing it money or goodwill.

Loss of Availability Assessment

The possible effect on the availability of the organization's systems and services was included into the evaluation of vulnerabilities discovered during the practical penetration testing. Weaknesses such as lack of network security controls, single points of failure, and insufficient redundancy were uncovered. Significant operational and financial effects for the organization might arise from exploiting these vulnerabilities, such as service outages, protracted downtime, or denial-of-service assaults.

Attack tree Diagram:



Practical Penetration Testing

Tools Used

The Purple Team's successful security assessment required the use of a wide range of tools and technologies throughout their actual penetration testing.

Description and Usage of Penetration Testing Tools

During the penetration testing, we used the following instruments:

1. Metasploit Framework: An effective exploitation framework for finding and exploiting security flaws in targets.
2. Nessus: A scanner for security flaws in computer systems and networks, capable of producing in-depth reports on its findings.
3. Burp Suite: A platform for doing human and automated tests on the security of online applications to identify flaws.
4. Nmap: Versatile network scanning utility that reveals all operating systems, services, and open ports on the target network.
5. Wireshark: A protocol analyzer for networks is a tool for monitoring and analyzing network traffic with the purpose of discovering and fixing security flaws.

10.2 Methodology and Techniques

In order to evaluate the effectiveness of the security measures in place at the company, the testers simulated actual attacks using a variety of methods.

Overview of the Penetration Testing Methodology Applied

The assessment used a standardized methodology for penetration testing, which consisted of the following steps:

1. Reconnaissance: Collecting intelligence about the company's computer setup, network topology, and any attack points.
2. Scanning and Enumeration: Locating any and all exposed ports, services, and security flaws in the target environment.
3. Exploitation: Using known security flaws as entry points to perform unauthorized actions or gain access to more sensitive data.
4. Post-Exploitation: Determine the level of breach, investigate the potential for further intrusion, and get access to sensitive information.
5. Reporting: Noting problems discovered and offering solutions to them in a report.

Description of Techniques Utilized during Testing

In order to find and exploit security holes, testers used a mix of human and automated methods during penetration testing. Some of these methods were:

1. Vulnerability Scanning: Using automated technologies to search for security holes in the company's infrastructure and software.
2. Password Cracking: Using specialized tools, users may see how secure their passwords are and whether or not they are easy to guess.
3. Social Engineering: Testing the organization's resistance to social engineering assaults by simulating attacks like phishing emails and phone calls.

4. **Exploitation:** Exploiting security holes to gain entry to a system or elevate privileges inside it.
5. **Web Application Testing:** Testing websites for common security flaws like SQL injection, cross-site scripting (XSS), and command injection by hand and with automated tools.

Findings and Recommendations

Detailed Report of Findings from Practical Penetration Testing

The realistic penetration testing revealed a number of loopholes and weak spots in the system and infrastructure of the company. Among these results are:

1. **Weak authentication mechanisms:** Weak passwords and the absence of multi-factor authentication leave the company vulnerable to intrusion.
2. **Unpatched software:** An attacker may take advantage of a system with outdated software because it lacks the latest security updates.
3. **Inadequate access controls:** Unauthorized users are able to access private data and do unapproved activities due to a lack of adequate access restrictions.
4. **Insufficient encryption protocols:** Inadequate encryption algorithms or poorly set up encryption techniques may compromise private information.
5. **Inadequate input validation:** By not adequately validating user input, web applications leave themselves open to typical threats like SQL injection and cross-site scripting.
6. **Lack of network segmentation:** As the potential effect of a breach grows, inadequate network segmentation enables attackers to move laterally throughout the network.

Recommendations for Remediation and Mitigation

Recommendations for fixing and preventing the vulnerabilities found in the real-world penetration tests are as follows:

1. Passwords should be difficult and strongly enforced; multi-factor authentication should be considered for mission-critical systems.
2. Create a method for swiftly fixing identified software flaws by applying updates and patches on a regular basis.
3. Improve access controls: Implement least privilege principles, ensuring that users only have access to the resources necessary for their roles and responsibilities.
4. Implement strong encryption: Utilize modern and robust encryption algorithms, properly configure encryption protocols, and enforce encryption for sensitive data in transit and at rest.
5. Enhance web application security: Implement input validation mechanisms, perform regular code reviews, and employ web application firewalls (WAFs) to protect against common attacks.
6. Implement network segmentation: Segment the network into different security zones and restrict communication between them to limit the potential impact of a compromise.

By implementing these recommendations, the organization can significantly improve its security posture, mitigate the identified vulnerabilities, and reduce the risk of successful attacks.

References

- [1] B. Vigliarolo, "NIST Cybersecurity Framework: A cheat sheet for professionals," March 5, 2021. [Online]. Available: <https://www.techrepublic.com/article/nist-cybersecurity-framework-the-smart-persons-guide/>.
- [2] A. Lamberti, "How to Perform a Network Assessment Like A Network Detective," Mar 14, 2023. [Online]. Available: <https://obkio.com/blog/how-to-perform-a-network-assessment/>.
- [3] G. Messina, "Kali Linux: Top 5 tools for post exploitation," July 20, 2021. [Online]. Available: <https://resources.infosecinstitute.com/topic/kali-linux-top-5-tools-for-post-exploitation/>.
- [4] A. Dizdar, "What is Penetration Testing? Process, Types, and Tools," May 29, 2022. [Online]. Available: <https://brightsec.com/blog/penetration-testing/>.
- [5] O. Д. S. N. P. V. E. Elena Pozdeeva, "Assessment of Online Environment and Digital Footprint Functions in Higher Education Analytics," *Education Sciences* 11(6):256, vol. 10.3390/educsci11060256, May 2021.